

IRENE LLC

GRC Case Study

Data Leakage Risk from Misconfigured Cloud Storage

PaySecure Ltd. — Financial Technology (FinTech)

INDUSTRY

FinTech / Payments

REGULATION

PCI-DSS | ISO 27001

ANALYST

Irene LLC — GRC Team

Tools: Survey | Interview Checklist | SWOT Analysis | Risk Register



Case Study Overview

Background

PaySecure Ltd., a FinTech company handling customer payment data, discovered during an internal compliance audit that a cloud storage bucket containing customer transaction logs was publicly accessible due to a misconfiguration error. No confirmed breach occurred, but the exposure of PII, card references, and transaction data poses a CRITICAL risk — violating PCI-DSS and ISO 27001 standards, leading to potential regulatory fines and reputational damage.

01

Survey

Assess employee awareness of cloud security policies and configuration practices

02

Interview Checklist

Structured questions for IT, Cloud, and Compliance teams to identify control gaps

03

SWOT Analysis

Evaluate PaySecure's internal strengths/weaknesses and external opportunities/threats

04

Risk Register

Document, score, and prioritize identified risks with mitigation actions



Cloud Security Awareness Survey

Target: All PaySecure staff handling cloud infrastructure, data, and compliance | Format: Anonymous 10-question survey

Section A — Awareness

Q1. Are you aware of PaySecure's cloud storage security policy?

Q2. Have you received training on secure cloud configuration in the last 12 months?

Q3. Do you know who is responsible for reviewing cloud bucket permissions?

Section B — Practices

Q1. How often are cloud storage access permissions reviewed? (Weekly / Monthly / Never)

Q2. Are public access settings audited before deploying new cloud storage buckets?

Q3. Do you use automated tools to scan for cloud misconfigurations?

Section C — Incident & Compliance

Q1. Have you ever noticed a misconfigured cloud bucket and reported it?

Q2. Are you familiar with PCI-DSS requirements for data storage security?

Q3. Does your team have a documented incident response plan for data exposure?

Q4. How confident are you in PaySecure's current cloud security controls? (1-5 scale)



Interview Checklist

Structured interviews with Cloud Engineering, IT Security, and Compliance teams to identify control gaps

Cloud Engineering Team

- ▶ Who has admin access to configure cloud storage bucket permissions?
- ▶ Is there an approval process before making any bucket publicly accessible?
- ▶ Are Infrastructure-as-Code (IaC) templates reviewed for security before deployment?
- ▶ How are bucket policy changes logged and monitored?

IT Security Team

- ▶ Are automated misconfiguration scanning tools (e.g. AWS Config, Defender for Cloud) in use?
- ▶ How frequently are cloud access logs reviewed for anomalies?
- ▶ Is there a process to alert when a bucket becomes publicly accessible?
- ▶ What DLP (Data Loss Prevention) controls are in place for cloud storage?

Compliance Team

- ▶ Has a PCI-DSS gap assessment been performed on cloud storage controls?
- ▶ Are cloud storage controls documented in the ISO 27001 Statement of Applicability?
- ▶ What is the regulatory notification timeline if a data breach is confirmed?
- ▶ When was the last third-party cloud security audit conducted?



SWOT Analysis — PaySecure Ltd.

Evaluating internal and external factors affecting PaySecure's cloud security posture

STRENGTHS

Internal — Positive

- Existing ISO 27001 certification framework in place
- Dedicated IT Security and Compliance teams
- Audit trail via cloud provider access logs
- PCI-DSS awareness among compliance staff
- Incident discovered internally before external exploit

WEAKNESSES

Internal — Negative

- No automated misconfiguration detection tooling
- Lack of cloud security configuration review process
- No Data Loss Prevention (DLP) controls on cloud buckets
- Insufficient staff training on secure cloud configuration
- No approval workflow for bucket permission changes

OPPORTUNITIES

External — Positive

- Implement CSPM tools (AWS Config, Microsoft Defender for Cloud)
- Adopt Zero Trust architecture for cloud access
- Strengthen ISO 27001 Annex A.9 & A.12 controls
- Conduct third-party cloud penetration testing

THREATS

External — Negative

- Regulatory fines — PCI-DSS non-compliance penalties
- ISO 27001 certification revocation risk
- Reputational damage if breach becomes public
- Threat actors scanning for exposed cloud buckets

TOOL 04 — RISK REGISTER



Risk Register — PaySecure Ltd.

Risk Scoring: Likelihood × Impact (1–5 scale) | Score ≥12 = CRITICAL | 8–11 = HIGH | 4–7 = MEDIUM | 1–3 = LOW

#	Risk Description	Likelihood (1–5)	Impact (1–5)	Risk Score	Level	Mitigation Action	Owner
R01	Public cloud bucket exposes customer PII & transaction logs	4	5	20	CRITICAL	Immediately set bucket to private; enable block public access	Cloud Eng.
R02	No automated misconfiguration detection — delayed discovery	4	4	16	CRITICAL	Deploy CSPM tool (AWS Config / Defender for Cloud)	IT Security
R03	PCI-DSS non-compliance — fines & audit failure	4	5	20	CRITICAL	Conduct PCI-DSS gap assessment; remediate findings	Compliance
R04	ISO 27001 certification at risk of revocation	3	5	15	CRITICAL	Review Annex A.9 & A.12 controls; update ISMS	Compliance
R05	Unauthorized data access by external threat actors	3	5	15	CRITICAL	Enable access logging; implement bucket policy deny-all	IT Security
R06	Staff lack training on secure cloud configuration	4	3	12	HIGH	Mandatory cloud security training for all technical staff	HR / Security
R07	No DLP controls on cloud storage buckets	3	4	12	HIGH	Implement DLP tagging and access restriction policies	Cloud Eng.
R08	Reputational damage & customer churn if breach disclosed	2	5	10	HIGH	Prepare incident communication plan; engage PR team	Executive



Identified Control Gaps

Gaps identified across People, Process, and Technology — mapped to PCI-DSS & ISO 27001

PEOPLE

No cloud security awareness training

PCI-DSS Req 12.6 | ISO A.7.2.2

HIGH

No defined owner for bucket permission reviews

ISO A.9.2.3

HIGH

PROCESS

No change management process for bucket configs

PCI-DSS Req 6.4 | ISO A.12.1.2

CRITICAL

No incident response plan for data exposure

PCI-DSS Req 12.10 | ISO A.16.1

CRITICAL

TECHNOLOGY

No CSPM / misconfiguration scanning tool deployed

PCI-DSS Req 11.3 | ISO A.12.6

CRITICAL

No DLP controls on cloud storage

PCI-DSS Req 3.4 | ISO A.13.2

CRITICAL



Mitigation Recommendations

Prioritized by urgency — Immediate (24–72hrs) | Short-Term (30 days) | Long-Term (90 days)

IMMEDIATE Within 24–72 Hours

- ✓ Set cloud bucket to PRIVATE — disable all public access immediately
- ✓ Rotate all credentials that had access to the exposed bucket
- ✓ Enable access logging on all cloud storage buckets
- ✓ Notify Legal & Compliance teams of potential PCI-DSS exposure

SHORT-TERM Within 30 Days

- ✓ Deploy CSPM tool (AWS Config, Microsoft Defender for Cloud, or Prisma Cloud)
- ✓ Implement DLP policies tagging PII and restricting cloud storage access
- ✓ Establish bucket permission change approval workflow (change management)
- ✓ Conduct mandatory cloud security training for all technical staff

- ✓ Perform full PCI-DSS gap assessment and remediate all findings
- ✓ Conduct third-party cloud penetration test and configuration audit

How to Build the Survey on Google Forms

Creating the PaySecure Cloud Security Awareness Survey | [Link: docs.google.com/forms/u/0/](https://docs.google.com/forms/u/0/)

1 Open Google Forms

- ▶ Go to: docs.google.com/forms/u/0/
- ▶ Click Blank Form or choose a template

2 Add Title & Description

- ▶ Enter: "Cloud Security Awareness Survey — PaySecure Ltd."
- ▶ Add description: purpose, confidentiality & estimated time

3 Create Questions

- ▶ Click "+" to add each question
- ▶ Types: Multiple Choice, Checkboxes, Short Answer
- ▶ Add IAM, Cloud Config & Compliance questions

4 Customise & Settings

- ▶ Click ⚙️ Settings — make all questions required
- ▶ Enable email collection if needed
- ▶ Use Theme to apply PaySecure brand colours

5 Share the Form

- ▶ Click Send → Email, Link, or Embed
- ▶ Share link with Cloud, IT Security & Compliance teams

 **Tip:** Use Section breaks in Google Forms to separate: Section A (Awareness) → B (Practices) → C (Incident & Compliance) — matching the PaySecure survey structure from Slide 3.

Irene LLC

GRC Risk Assessment — PaySecure Ltd.

- ✓ Survey — 10 questions across Awareness, Practices & Compliance
- ✓ Interview Checklist — 12 questions for Cloud, IT Security & Compliance teams
- ✓ SWOT Analysis — Strengths, Weaknesses, Opportunities & Threats identified
- ✓ Risk Register — 5 CRITICAL & 3 HIGH risks documented & scored
- ✓ Control Gaps — 8 gaps mapped to PCI-DSS & ISO 27001 controls
- ✓ Recommendations — 12 prioritized mitigation actions across 3 time horizons

Questions?

IRENE LLC

PaySecure's Data & Cloud Security Risk Assessment Report 2026



REPORTED BY:

Irene Adesina, GRC Team

RESPONSE RATE:

90%

REPORTED ON:

June 26, 2026

TARGET AUDIENCE:

IT Team & Developer Team

SURVEY POPULATION:

10 respondents (9 responses)

Objective: This report assesses PaySecure's security posture by evaluating data protection practices, control effectiveness, and employee compliance awareness across the IT and Developer teams.

Survey Findings Overview

The Q1 2026 GRC investigation identified significant security gaps specifically regarding Access Control, Cloud Storage Visibility, and Data Classification. With a 90% response rate from the IT and DevOps teams, the data reveals critical misconfigurations and a lack of standardised processes. Current practices pose a HIGH risk for data leakage and non-compliance with PCI-DSS and ISO 27001 frameworks.

90%

Response Rate

9 of 10 responded

3

CRITICAL Risks

Data, Cloud, IRP

2

HIGH Risks

MFA, Framework

73%

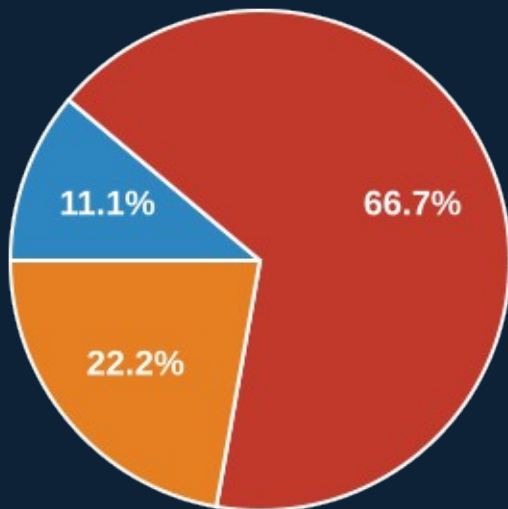
Avg Non-Compliance

Across all 5 areas

Survey Area	YES	NO	MAYBE	Risk Level
Data Classification	11.1%	66.7%	22.2%	CRITICAL
Cloud Config Review	0%	77.8%	22.2%	CRITICAL
MFA on Critical Systems	22.2%	66.7%	11.1%	HIGH
Cybersecurity Framework	0%	77.8%	22.2%	HIGH

Is sensitive data classified (public, internal, confidential)?

Survey Area: Data Classification | 9 Responses | Source: PaySecure GRC Survey 2026



YES — 11.1%

Observation

66.7% of respondents confirmed NO data classification policy exists. Only 11.1% confirmed classified data — indicating most PII and transaction data is untagged and unprotected.

GRC Finding

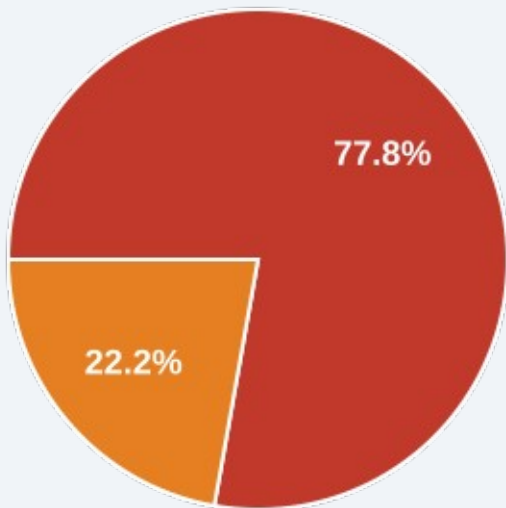
Absence of data classification means PCI-DSS Requirement 3 (Protect Stored Data) is not being met. Customer card data and PII cannot be properly secured without classification.

✓ **Recommendation:** Implement a data classification policy (Public / Internal / Confidential / Restricted) aligned to PCI-DSS Req 3

MAYBE — 22.2%

Is cloud configuration reviewed against best practices?

Survey Area: Cloud Configuration Review | 9 Responses | Source: PaySecure GRC Survey 2026



 YES — 0%

Observation

77.8% said NO cloud configuration reviews are conducted. 22.2% were unsure. Zero respondents confirmed regular reviews — the root cause of the misconfigured public bucket.

GRC Finding

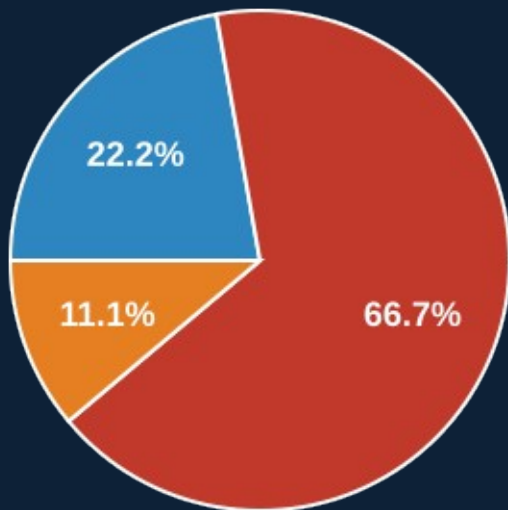
No cloud configuration review process is the direct cause of the publicly accessible storage bucket. This violates ISO 27001 Annex A.12.1 (Operational Procedures) and PCI-DSS Req 6.4.

✓ **Recommendation:** Deploy CSPM tool (AWS Config / Defender for Cloud); establish quarterly cloud config review process

 MAYBE — 22.2%

Is MFA enabled for critical systems?

Survey Area: MFA on Critical Systems | 9 Responses | Source: PaySecure GRC Survey 2026



YES — 22.2%

Observation

66.7% confirmed MFA is NOT enabled on critical systems. Only 22.2% confirmed MFA is active — leaving the majority of critical infrastructure vulnerable to credential-based attacks.

GRC Finding

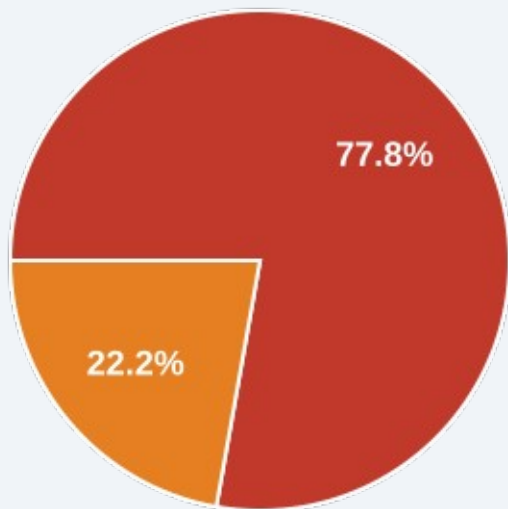
Lack of MFA on critical systems violates PCI-DSS Requirement 8.3 (Secure Authentication) and ISO 27001 Annex A.9.4. A compromised credential could grant full access to payment data.

✓ **Recommendation:** Enable MFA on ALL critical systems immediately — prioritise payment processing and admin portals

MAYBE — 11.1%

Is a cybersecurity framework adopted (ISO/NIST)?

Survey Area: Cybersecurity Framework Adoption | 9 Responses | Source: PaySecure GRC Survey 2026



Observation

77.8% confirmed NO cybersecurity framework is formally adopted. 22.2% were unsure. This means there is no structured baseline for security controls or compliance measurement.

GRC Finding

Without a formal framework (ISO 27001 or NIST CSF), PaySecure has no standardised approach to risk management. This makes audit readiness and regulatory compliance extremely difficult.

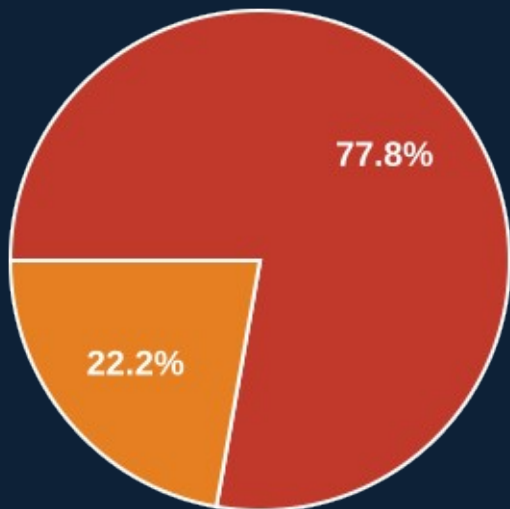
YES — 0%

✓ **Recommendation:** Formally adopt ISO 27001 or NIST CSF as the organisational cybersecurity framework

MAYBE — 22.2%

Is an Incident Response Plan (IRP) documented?

Survey Area: Incident Response Plan | 9 Responses | Source: PaySecure GRC Survey 2026



YES — 0%

Observation

77.8% confirmed there is NO documented Incident Response Plan. 22.2% were unsure. Zero respondents confirmed an IRP exists — PaySecure has no formal breach response capability.

GRC Finding

Absence of an IRP violates PCI-DSS Requirement 12.10 (Incident Response Plan) and ISO 27001 Annex A.16.1. In the event of a confirmed data breach, PaySecure cannot respond effectively.

✓ **Recommendation:** Develop and document an Incident Response Plan aligned to PCI-DSS Req 12.10 and ISO 27001 A.16.1

MAYBE — 22.2%

Consolidated Recommendations

Prioritised actions to remediate all 5 identified security gaps — June 2026

1	Data Classification Create and enforce a data classification policy (Public/Internal/Confidential/Restricted). Tag all PII and transaction data. Assign data owners.	 30 Days	CRITICAL
2	Cloud Configuration Deploy CSPM tool immediately. Conduct full audit of all cloud storage buckets. Establish quarterly config reviews with sign-off.	 Immediate	CRITICAL
3	Incident Response Plan Draft and test an IRP aligned to PCI-DSS Req 12.10 and ISO 27001 A.16.1. Define escalation paths, communication plans, and breach notification timelines.	 30 Days	CRITICAL
4	MFA Enforcement Enable MFA on ALL critical systems — admin portals, cloud consoles, payment processing systems. Use authenticator apps, not SMS.	 14 Days	HIGH
5	Framework Adoption Formally adopt ISO 27001 or NIST CSF. Appoint a GRC lead. Schedule gap assessment and begin Statement of Applicability (SoA) documentation.	 90 Days	HIGH